

Security Response Headers

Storefront Next sends security response headers by default. Every storefront that you generate from the template inherits these headers. The headers help protect shoppers from common web attacks, such as cross-site scripting (XSS), clickjacking, and protocol downgrade.

Unlike Composable Storefront (PWA Kit), which sets headers explicitly in your storefront code, Storefront Next manages these headers for you. The defaults ship from the `@salesforce/storefront-next-runtime` package, so you don't maintain them yourself. To support an external integration, extend the defaults through `config.server.ts` or an environment variable.

Default Headers

The table lists the headers that Storefront Next sends with every page response.

Header	Default Value
Content-Security-Policy	See Content Security Policy Directives .
Strict-Transport-Security	<code>max-age=15552000; includeSubDomains</code> (sent on Managed Runtime only, and suppressed during local development)
X-Frame-Options	<code>SAMEORIGIN</code>
X-Content-Type-Options	<code>nosniff</code>
Referrer-Policy	<code>strict-origin-when-cross-origin</code>

Contents

Default Headers

[Add Headers for an External Integration](#)

[Override Headers with an Environment Variable](#)

[Related Topics](#)



The headers apply to pages that your storefront renders. They don't apply to the Managed Runtime health check, the B2C Commerce API (SCAPI) proxy path, or static assets, because other layers serve those responses.

Content Security Policy Directives

The Content Security Policy (CSP) controls which origins a page loads content from. The default policy is tuned for the Storefront Next stack: server-side rendering, Dynamic Imaging Service (DIS) images, Cloudflare Turnstile, Tailwind CSS inline styles, and SCAPI as the only outbound API origin.

Directive	Default Value
<code>default-src</code>	<code>'self'</code>
<code>script-src</code>	<code>'self'</code> <code>https://challenges.cloudflare</code> <code>'nonce-<per-request>'</code>
<code>style-src</code>	<code>'self' 'unsafe-inline'</code>
<code>img-src</code>	<code>'self' data:</code> <code>https://*.commercecloud.sales</code> <code>https://*.demandware.net</code>
<code>font-src</code>	<code>'self' data:</code>

[Try for free](#)

```
https://*.demandware.net
https://challenges.cloudflare
```

```
frame-      https://challenges.cloudflare
src
```

```
frame-      'self'
ancestors
```

```
form-      'self'
action
```

```
base-uri    'self'
```

```
object-     'none'
src
```

```
upgrade-    Enabled
insecure-
requests
```

Add Headers for an External Integration

To add an origin for an external integration, such as an analytics provider or a third-party widget, extend the defaults in `config.server.ts`. Import `defaultCspDirectives`, spread it, and add your origin to the relevant directive.



Important

Each directive that you set replaces the default for that directive. Spread `defaultCspDirectives` and add your origin so that your storefront keeps the values that Storefront Next requires.





```
5  ...
6  security: {
7    headers: {
8      csp: {
9        directives: {
10         ...defaultCspDirectives,
11         "script-src": [...defaultCspDirectives["script-src"],
12         "connect-src": [...defaultCspDirectives["connect-src"],
13       },
14     },
15   },
16 },
17 },
18 });
```

To add an identity provider for social login, extend `connect-src` with the provider's origins. For more information, see [Implement Social Login for Storefront Next](#).

Warning

Report-only mode doesn't block content, so it provides no protection. Don't use report-only mode for a production deployment. To discover the origins that an integration uses, deploy with `csp: { reportOnly: true }` in a test environment, where the browser reports violations to the DevTools console. After you add the origins, set `reportOnly` to `false` to enforce the policy.

Override Headers with an Environment Variable

To change a header without a code change, use the `PUBLIC__` environment-variable override. The variable path uses double-underscore (`__`) separators.

```
1  # Turn on CSP report-only mode:
2  PUBLIC__app__security__headers__csp__reportOnly=true
3
4  # Turn off the Strict-Transport-Security header:
5  PUBLIC__app__security__headers__hsts=false
```

An environment variable replaces the entire `directives` map, not an individual directive, because the variable path uses `__` as its separator and directive names contain hyphens,

[Try for free](#)

```
1 # Replace the entire CSP directives map
2 PUBLIC__app__security__headers__csp__di
```

Because an environment-variable override replaces all defaults, reserve it for unusual cases. For most changes, edit `config.server.ts` and spread `defaultCspDirectives`. For more information about environment-variable overrides, see [Project Configuration](#).

Related Topics

- [Project Configuration](#)
- [Implement Social Login for Storefront Next](#)
- [Limit Access to a Storefront Under Development](#)

DID THIS ARTICLE SOLVE YOUR ISSUE?

Let us know so we can improve!

[Share your feedback](#)

DEVELOPER CENTERS

[Heroku](#)
[MuleSoft](#)
[Tableau](#)
[Commerce Cloud](#)
[Lightning Design System](#)
[Einstein](#)
[Quip](#)

POPULAR RESOURCES

[Documentation](#)
[Component Library](#)
[APIs](#)
[Trailhead](#)
[Sample Apps](#)
[AppExchange](#)

COMMUNITY

[Trailblazer Commu](#)
[Events and Calend](#)
[Partner Communit](#)
[Blog](#)
[Salesforce Admins](#)
[Salesforce Architec](#)

© Copyright 2026 Salesforce, Inc. [All rights reserved](#). Various trademarks held by their respective owners. Salesforce, Inc. Salesforce Tower, 415 Mission Street, 3rd Floor, San Francisco, CA 94105, United States

[Legal](#) [Terms of Service](#) [Privacy Information](#) [Responsible Disclosure](#) [Trust](#) [Contact](#)

[Use of Cookies](#) [Cookie Preferences](#) [Your Privacy Choices](#)

